

Technology Plus

Unit 7: Security

6.2.1 – Security Awareness

Lesson Overview:

This lesson introduces students to the importance of security awareness, with a focus on recognizing phishing attacks and identifying malicious or compromised content. Students will learn how attackers use social engineering to manipulate users and how seemingly harmless content from emails, links, or files can pose a threat to personal or organizational security.

Students will:

- Define social engineering and explain its connection to phishing.
- Identify different types of phishing attacks.
- Explain what malicious or compromised content is and how it is used in attacks.
- Identify signs of phishing and compromised content.

Guiding Question: How can understanding phishing and other vectors for malicious content help you protect yourself and others from social engineering attacks?

Suggested Grade Levels: 8-12

Technology Needed: Yes

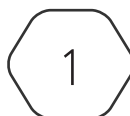
Approximate Time Required: 55-75 minutes

Standards:

CompTIA Tech+ FC0-U71 Objective

- 6.2 – Explain methods to secure devices and security best practices.
 - Security awareness
 - Social engineering
 - Phishing
 - Malicious or compromised content

This content is based upon work supported by the US Department of Homeland Security's Cybersecurity & Infrastructure Security Agency under the Cybersecurity Education Training and Assistance Program (CETAP).



Lesson Background

Background Information:

Security awareness focuses on making users aware of the tactics malicious actors use to carry out an attack. Many of these focus on the human element, which is often considered the weakest link in cybersecurity. The lesson covers concepts that often result from a mistake or a missed error on the part of the typical user. It does review some concepts from previous lessons in 6.1 on the CIA Triad, so students may have prior knowledge to drive discussions.

Topics include:

Social engineering, the act of manipulating individuals into revealing confidential information or performing actions that compromise security.

Phishing is the most common type of social engineering attack and includes fraudulent emails or messages that trick victims into clicking links, entering credentials, or downloading malware.

Malicious or compromised content may look like legitimate files, websites, or links but are designed to harm systems, steal data, or gain unauthorized access.

Awareness is the first line of defense. Teaching users to recognize suspicious content helps reduce the risk of falling victim to these attacks.

Materials Needed:

Materials per Class	• Lesson Guide 6.2.1 – Security Awareness • Lesson Slides 6.2.1 – Security Awareness • Activity Slides 6.2.1 – Cybersecurity Awareness Poster
Materials per Group	• Markers, color pencils, or other writing utensils • Blank paper, poster/chart paper • Optional: Supplies to make posters stand out or pop like bulletin board borders, decals, access to a printer for students to use images, etc.
Materials per Student	• Student Handout 6.2.1 – Security Awareness • Student Notes 6.2.1 – Security Awareness • Assessment 6.2.1 – Security Awareness (optional)

Lesson Background

Cyber Terms:

Term	Definition
attack vector	the method or pathway a malicious actor uses to gain unauthorized access to a system, network, or application
social engineering	the manipulation of people through psychological or social tactics to gain unauthorized access to systems, data, or confidential information
phishing	a type of online scam where criminals impersonate legitimate organizations to steal sensitive information
smishing	phishing through text messages or other phone messaging applications
vishing	phishing via a voice call or other voice messaging systems
spear phishing	phishing aimed at a specific target who has undergone recon from a malicious actor to provide a targeted attack
whaling	a specific type of phishing/spear phishing directed at high profile targets such as CEOs or personnel who could have higher permissions and access
baiting	manipulating a potential victim with something valuable to lure them into releasing information or performing an action they would normally not do
typosquatting	when an adversary uses a domain name with similar spelling as a legitimate one in hopes that a user will have a typo when entering the URL
watering hole attack	when a website that is commonly visited by a specific group is compromised to install malware or gain credentials with the end goal to access more secure systems

6.2.1 – Security Awareness

Guiding Question: How can understanding phishing and other vectors for malicious content help you protect yourself and others from social engineering attacks?

Lesson Launch (3-5 minutes)

- Start by asking if students have thought about how malicious actors even go about attacking potential victims.
- We often see the results of an attack whether it is a data breach, identity theft, malware installation, etc.; however, movies even tend to skip over the process or just show someone busy typing away for a few minutes until they yell “I got access.”
- Use this to drive the discussion into attack vectors and that in most cases, it is the human factor that leads to an attack being successful.

Attack Vectors and Social Engineering Review (10-15 minutes)

- Distribute Student Handout 6.2.1 – Security Awareness to students and encourage them to fill in answers as you go through today’s lesson.

Attack Pathways

- An **attack vector** is the method or pathway a malicious actor uses to gain unauthorized access to a system, network, or application.
 - Another way to look at this is with the disease Malaria. The disease uses mosquitos as a primary vector or means to infect humans. Eliminating the vector means the disease could not spread nearly as fast or might be stopped completely.
- Attack vectors are always changing and evolving. Being aware of the vectors malicious actors use to carry out a cyber-attack can prevent it from spreading as the weakest link is often the human aspect.
- The key point is that humans can still fall victim to attacks, regardless of the technology we have in place to protect data.

Reviewing Social Engineering and Phishing Basics

- **Social engineering** is the manipulation of users through social interactions to gain access to sensitive information or persuade them to perform an action, such as downloading a malicious file.
- It can be performed by one person or several people, physically or digitally, in the same building or half-way around the world.
- Human nature, behavior, and social interactions used in a manipulative way serve as the vector for social engineering attacks.
- **Phishing** attempts to gain sensitive information through fraudulent means such as a link or soliciting a

response via email, text, or other messaging.

- **Smishing** uses text messages or other phone messaging apps, while **vishing** uses voice calls to perform phishing attacks.

Pro Phishing (10-15 minutes)

Personalized Phishing and Baiting

- Technology has become ingrained in nearly everyone's daily life. Because of this, there is a ton of information available out there on just about any individual.
- **Spear phishing** uses information that is available and is directed at a specific target that has usually been under recon from the malicious actor.
- **Whaling** is a more specific type of phishing/spear phishing directed at high profile targets such as a CEO or high-ranking officials.
- Recon is intelligence gained by an adversary studying an individual's online presence and digital footprint, such as social media accounts. They could use open-source intelligence options or paid services.
- Use the generated social media post on the slide to have students discuss ways to perform a phishing attack against the victim.
- **Baiting** is tempting a potential victim with something valuable to lure them into acting. In most cases the link or file serves as a vector and results in malware being installed

Signs of Phishing

- Start by asking students what they have experienced and what they notice about potential phishing scams, including the example shown.
- Signs of phishing can include, but are not limited to:
 - Informal text, typos, or poor grammar
 - Tone of the message having a sense of urgency or being authoritative
 - Incorrect, misleading, or ambiguous links
 - Unofficial email addresses.

Websites as Vectors (5-10 minutes)

Website Typos

- Typos happen more often than we realize, and adversaries take advantage of this.
- **Typosquatting** occurs when an adversary uses a domain name with similar spelling as a legitimate one in hopes that a user will have a typo when entering the URL. This could possibly lead to a malicious site that mimics the original and could be used to gain sensitive information.
- Typosquatting, also called URL hijacking, sting sites, cousin domains, or simply fake URLs, became such an issue over time that companies began purchasing domains that were close to the same spelling just to prevent these attacks.
 - As an example, Google owns several domains, such as googel.com that either do not have real

webpages or automatically redirect to the real google webpage.

Watering Hole Attacks

- **Watering Hole attacks** infect a website that is commonly visited by a specific group to install malware or gain credentials with the end goal to access more secure systems using the compromised device or login credentials.
 - The key is by attacking a less obvious or less secure website, the attacker can gain credentials or install malware that would give them access to a target that would normally be much more difficult to attack head-on.
 - Example: Several workers at a local plant also play softball on the weekends. Scheduling, tournament information, and registration are all handled through a simple website created by a plant worker. It lacks robust security protocols and is breached by an adversary. The adversary then uses the information gained to login to the employee portal for the plant.

Identifying Compromised Content

- Compromised websites will have many of the same red flags that phishing has:
 - Informal text, typos, or poor grammar.
 - Incorrect, misleading, or ambiguous links.
- Whether the content is from an email, website, or other means, you should always:
 - Double-check links and inspect URLs to make sure they are correct.
 - Never click on unexpected links or attachments.
 - Keep software, browsers, and anti-virus updated.
 - Be vigilant in examining the context of messages.
 - Do not use the same credentials across multiple devices, platforms, and applications.

Activity: Security Awareness Poster (25-30 minutes)

- Students will work in pairs or groups to create a virtual or physical security awareness poster about one of the specific attacks mentioned in the lesson.
- If they are creating physical posters, then they will need the supplies listed in the materials section above.
- The instructions, topics, and rubric are included in Activity Slides 6.2.1 – Cybersecurity Awareness Poster.
- Topics include:
 - Phishing
 - Smishing
 - Vishing
 - Spear phishing
 - Whaling
 - Baiting

- Typosquatting
- Watering Hole Attacks
- Each poster should include the following:
 - Definition of the threat
 - A realistic example or scenario
 - An example of what the attacker could be after
 - Two red flags that could help avoid the attack
- Classes could be divided and given the topics or draw topics to prevent duplicate posters from being created.
- A sample rubric is included below with a sample response that is optional to show to students. The example is hidden and needs to be unhid in the slide deck to show students.
- Posters can be displayed in the classroom or public areas of the school to raise security awareness.

Criteria	Excellent (4 pts)	Good (3 pts)	Needs Improvement (2 pts)	Incomplete (1 pt)
Content Accuracy	Information is accurate, relevant, and clearly explains the threat.	Minor inaccuracies or missing small details.	Some information is unclear or inaccurate.	Major inaccuracies; threat is not explained.
Realistic Scenario/Example	Clear, creative, and realistic example that enhances understanding.	Example is present and somewhat realistic.	Vague or unclear example.	No example is included.
Prevention Tips (Minimum 2)	Three or more clear and specific tips included.	Two clear tips included.	One vague or unclear tip.	No prevention tips included.
Visual Design & Creativity	Eye-catching, well-organized, and creative layout.	Organized with some visual appeal.	Some attempt at visuals or layout.	Poorly organized or lacks visuals.
Mechanics (Spelling & Grammar)	No errors in spelling or grammar.	1–2 minor errors.	Multiple errors, but meaning is mostly clear.	Frequent errors that interfere with understanding.

Putting It All Together (3-5 minutes)

Discussion Questions

- Why is phishing so successful despite people knowing it exists?

It attacks our human nature and social actions, many of which we do out of habit.

- What's more effective, technology or awareness, when it comes to preventing social engineering attacks? Why?

Answers may vary. Some defenses can prevent phishing attempts from reaching the end user by analyzing message content, links, URLs, or files. In other cases, even advanced systems can allow certain things to pass through, and the user becomes a victim because they do not expect it to be out of the ordinary.

- What advice would you give a friend who just received a suspicious email?

Student answers will vary. They could report it to the organization the email is supposedly coming from or to a trusted adult. They could also block it, change their credentials for that account, and/or notify others that there could be a phishing attempt going around.